WANDR TRAVEL GROUP

Risk Management Report

Mercy Oji

February 28, 2026

University of Dallas

CYBS 8396: Strategic Cybersecurity Practicum

Table of Contents

1. **Executive Summary**

2. **Risk Assessment Approach**

    2.1 Data Classification Scheme

    2.2 Likelihood and Impact Rating

3. **Information Asset Risk Analysis**

    3.1 Customer Payment Processing Environment

    3.2 Customer Personal Data Repository

    3.3 AI-Powered Recommendation Engine

    3.4 Mobile Application Platform

4. **Risk Summary and Prioritization**

    4.1 Asset Risk Matrix

    4.2 Recommended Security Controls Summary

5. **Conclusion**

6. **References**

Executive Summary

Wandr Travel Group (WTG) is a mid-sized travel technology company operating in the competitive travel and hospitality industry. The organization provides comprehensive web and mobile platforms, supported by artificial intelligence-powered travel-planning tools that deliver personalized recommendations based on customer preferences, historical booking data, and behavioral analytics. Through its digital ecosystem, customers create secure accounts, submit personal and payment information, and purchase flights, hotels, rental cars, and complete travel packages. WTG's high-level business strategy centers on leveraging advanced AI capabilities, cloud-based infrastructure, and data-driven personalization to deliver exceptional customer experiences at scale, expand market share across North America and Europe, and maintain competitive differentiation through technological innovation and superior customer service.

This report outlines a strategic cybersecurity risk management plan for WTG, focusing on four critical information assets: the customer payment processing environment, the customer personal data repository, the AI-powered recommendation engine, and the mobile application platform. These assets are vital to WTG's operations and profitability, storing sensitive customer and financial data while enabling core business functions. Given that data breaches are increasingly costly (the average breach cost reached $4.88 million in 2024), WTG's high-level strategy emphasizes proactive risk management to protect customer trust, comply with regulations, and ensure service reliability. The purpose of this report is to assess the risks facing each key asset and recommend controls to strengthen WTG's security posture (IBM Security, 2023).

We classify each asset under WTG's data classification scheme (Public, Internal, Confidential, or Restricted) based on sensitivity. Both the customer payment processing environment and the personal data repository are categorized as Restricted because they contain confidential customer personal and payment data, and a breach could severely damage WTG's finances and reputation. The AI recommendation engine and mobile application platform are classified as Confidential (sensitive to business but not public) because they handle proprietary algorithms and customer session data. For each asset, we identify a major vulnerability and assess its likelihood of occurrence and business impact. Likelihood and impact are rated qualitatively (low, medium, high) using NIST (2012) criteria. We found that the payment processing environment and personal data repository pose high-risk vulnerabilities, including SQL injection and weak access controls, given the high impact of a customer data breach and a moderate-to-high likelihood of attack. The AI engine and mobile platform exhibit moderate-risk issues, with significant impact somewhat mitigated by existing controls and cloud security measures.

Each vulnerability is paired with 3-5 recommended security controls to mitigate the risk to an acceptable level. Overall, this strategic risk management approach will enable WTG to prioritize protecting its most valuable assets, reduce the likelihood of costly breaches, and maintain resilient operations. The concluding section of the report explains why cybersecurity breaches persist despite risk assessments and how we will communicate WTG's risk posture and tolerance to stakeholders using the results of this assessment (Whitman & Mattord, 2018).

Risk Assessment Approach

WTG's risk assessment methodology follows industry-standard frameworks, including NIST SP 800-30 (NIST, 2012) and NIST SP 800-39 (NIST, 2018). This structured approach ensures consistency, repeatability, and defensibility in risk decisions while enabling effective communication with both technical and executive stakeholders.

2.1 Data Classification Scheme

WTG uses a four-tier data classification scheme to categorize information assets by sensitivity and regulatory requirements. Public data is intended for public release and has no adverse impact if disclosed. Internal data is proprietary business information for internal use; unauthorized disclosure could moderately harm competitiveness. Confidential data contains sensitive business and customer information that must be protected from disclosure. Restricted data is highly sensitive and critical to the company's survival; leaks or unauthorized access could cause severe financial, legal, or reputational damage. Restricted information includes customer payment card data and authentication credentials that must remain strictly confidential under regulatory requirements such as PCI DSS (Payment Card Industry Security Standards Council, 2022). Access to Restricted information is limited to a strict need-to-know basis. WTG applies stricter security controls, encryption, monitoring, and access restrictions to Confidential and especially Restricted data. Each asset in this report is classified by data sensitivity, as summarized in Table 1, ensuring the most sensitive assets receive the strongest protection (Whitman & Mattord, 2018).

Table 1. Summary of Assets, Classifications, and Key Risk Factors

Asset	Data Classification	Major Vulnerability	Likelihood	Impact
Customer Payment Processing	Restricted	SQL injection via payment APIs	Medium	High
Customer Personal Data	Restricted	Weak authentication & access control	Medium	High
AI Recommendation Engine	Confidential	Cloud misconfiguration	Medium	Medium
Mobile Application	Internal	Insecure data storage	Medium	Medium

WTG evaluates asset value to profitability using a multi-factor analysis that incorporates revenue dependency, operational criticality, contribution to competitive advantage, and regulatory compliance requirements. Asset profitability is assessed across four dimensions:

- Revenue Generation Impact: Direct contribution to booking revenue and customer acquisition
- Operational Dependency: Degree to which business continuity relies on asset availability
- Competitive Differentiation: Unique value proposition enabled by the asset
- Regulatory/Compliance Value: Cost avoidance through regulatory compliance maintenance.

2.2 Likelihood and Impact Rating

WTG assesses risk by evaluating the likelihood of a successful exploit and the impact on operations using a three-level qualitative scheme: High, Medium, Low. Likelihood represents the probability of exploitation, taking into account threat activity, asset exposure, and existing controls. Impact

evaluates potential damage to confidentiality, integrity, and availability, as well as financial, legal, and reputational consequences, consistent with NIST's risk assessment methodology (NIST, 2012). A high likelihood indicates active threats and easily exploitable vulnerabilities widely observed across the industry. Medium indicates a reasonable probability of occurrence, depending on specific conditions. Low means it is unlikely under normal conditions or requires sophisticated attacks. High impact denotes catastrophic consequences, major financial losses, legal penalties, loss of customer trust, or operational paralysis. Medium impact is significant but manageable. Low impact is minimal and localized.

For each asset, we assign ratings based on threat analysis and business consequences. High/High combinations indicate critical risks that require urgent mitigation. This qualitative approach enables WTG to prioritize resources for the most severe risks (NIST, 2012).

Table 2. Likelihood Scale

Score	Rating	Definition
1	**Low**	Unlikely due to limited exposure or strong existing controls
2	**Medium**	Possible due to known vulnerabilities or moderate exposure
3	**High**	Likely due to common industry incidents or a broad attack surface

Table 3. Impact Scale

Score	Rating	Definition
1	**Low**	Limited financial or operational disruption
2	**Medium**	Noticeable disruption or moderate financial impact
3	**High**	Severe revenue loss, regulatory penalties, or significant downtime

Risk Score Formula

$$\textbf{Risk Score} = \textbf{Likelihood} \times \textbf{Impact}$$

Risk levels:

- 1-2: Low Risk
- 3-4: Moderate Risk
- 6: High Risk
- 9: Critical Risk

Information Asset Risk Analysis

3.1 Customer Payment Processing Environment

Asset Description & Value: WTG's customer payment processing environment handles all credit and debit card transactions for flight, hotel, and travel package bookings. Processing over 50,000 transactions daily, with an average of $850 per booking ($15.5 million in daily volume), the system is classified as Restricted under WTG's data classification scheme, requiring strict PCI DSS compliance (Payment Card Industry Security Standards Council, 2022). A compromise could trigger catastrophic financial disruption and a loss of customer trust.

Major Vulnerability: SQL injection in web applications and APIs that interact with payment databases. If input fields aren't properly sanitized, attackers could inject malicious SQL to disclose payment information or modify transactions. The 2017 Equifax breach exposed 147 million records through an unpatched SQL injection flaw. For WTG, a breach would trigger PCI DSS forensic investigations ($50,000-$500,000), card brand fines, possible merchant account loss, and severe damage to customer trust. Payment breaches average $4.88 million in total costs (IBM Security, 2023).

Significance: Beyond privacy violations, leaked payment credentials enable financial fraud and identity theft. The 2017 Equifax breach, which exposed 147 million records through an unpatched SQL injection flaw, underscores the critical nature of this vulnerability. For WTG, a payment data breach would trigger mandatory PCI DSS forensic investigations costing $50,000-$500,000, potential fines from card brands, possible loss of merchant account privileges, and severe damage to customer trust. Payment card breaches average $4.88 million in total costs, including notification, remediation, legal fees, and customer compensation (IBM Security, 2023).

Likelihood (Medium): SQL injection attacks are common, and web application attacks remain among the top attack vectors (Verizon, 2024). However, standard secure coding practices and input validation can prevent basic exploitation.

Impact (High): A breach could compromise payment data for WTG's 2.3 million users, leading to customer fraud, PCI DSS violations with penalties of $5,000-$100,000 per month (Payment Card Industry Security Standards Council, 2022), and possible merchant processing termination.

Recommended Controls

To reduce the risk of SQL injection and protect this Restricted asset, several controls should be implemented as part of a layered defense strategy.

Secure Coding and Input Validation: All web application inputs that interact with payment databases must be rigorously validated and sanitized. Developers should rely exclusively on parameterized queries or stored procedures to prevent user-provided data from being executed as code. Providing secure coding training based on the OWASP Application Security Verification Standard (OWASP Foundation, 2021) and conducting peer code reviews focused on injection flaws can prevent issues before production. Code review should be mandatory for all payment-processing components.

Web Application Firewall (WAF): Deploying a WAF in front of payment processing APIs can identify and block SQL injection attempts in real time using signature- and behavior-based detection. A properly configured WAF, integrated with logging and alerting tools, serves as an effective early warning system, providing security teams with visibility into attack attempts and enabling rapid responses to emerging threats.

Database Hardening and Patch Management: The payment database management system must remain fully up to date to address known vulnerabilities. Outdated or unpatched systems are among

the most common causes of breaches, as the Equifax incident demonstrates through its catastrophic consequences from delayed patching. Disable unused database features, remove default accounts, and follow least-privilege principles for database access. Payment databases should follow an expedited patching schedule, applying critical security updates within 48 hours of release (NIST, 2023).

Strong Access Controls and Network Segmentation: Only a small number of systems and individuals should have direct access to the payment database. Multi-factor authentication should be mandatory for all administrative accounts, and network segmentation should ensure that only application servers and approved database administrators can issue queries. Payment processing should run in a completely isolated network segment with strict firewall rules that prevent lateral movement from other parts of the infrastructure.

Encryption and Tokenization: All payment card data should be encrypted at rest using AES-256 and in transit using TLS 1.3 or higher. Better yet, implement tokenization so that actual card numbers are never stored in WTG's environment, only non-sensitive tokens that reference cards stored securely at the payment processor. Database backups containing payment information must be encrypted and stored securely off-site with strict access controls (Payment Card Industry Security Standards Council, 2022).

By combining these measures, WTG can significantly reduce the likelihood of successful SQL injection attacks while limiting the impact if defenses are bypassed. Input validation and WAFs directly address the vulnerability, while access controls, segmentation, and encryption provide defense-in-depth layers that strengthen the confidentiality and integrity of WTG's most financially critical customer information.

3.2 Customer Personal Data Repository

Asset Description & Value: The customer personal data repository holds personally identifiable information (PII) for WTG's 2.3 million active customers, including names, email addresses, phone numbers, physical addresses, passport information (for international bookings), travel preferences, booking history, and behavioral analytics used to power AI-driven recommendations. This centralized repository underpins personalized customer experiences and represents significant business value beyond transaction processing, enabling WTG's competitive differentiation through tailored travel suggestions, targeted marketing campaigns, and customer relationship management. Because this asset contains extensive PII subject to privacy regulations, we classify it as Restricted. GDPR compliance is mandatory for European customers, with potential penalties of 4% of annual global revenue or €20 million, whichever is greater (European Parliament & Council, 2016). A customer data breach would severely damage brand reputation, drive customer churn of 15-25%, and expose WTG to class-action litigation. This data also fuels machine learning models that generate approximately $12 million in incremental revenue annually through personalized upselling and targeted promotions.

Major Vulnerability: Weak authentication and access controls for customer data APIs. The current implementation relies on basic API keys without multi-factor authentication, lacks granular role-based

access control, and provides insufficient data access monitoring. Customer service, marketing teams, and third-party partners have overly broad access privileges. Compromised API credentials could enable systematic customer data harvesting, competitive intelligence theft, or dark web sales, undermining WTG's trust-based business model (IBM Security, 2023).

Significance: Weak access controls enable both external attackers and malicious insiders to extract customer data at scale. Compromised API credentials remain a leading cause of data breaches. An attacker with stolen API keys could systematically harvest customer records, exfiltrate marketing lists to competitors, or sell personal information on dark web marketplaces. For WTG's business model, which depends on customer trust and data-driven personalization, such a breach would undermine core competitive advantages, trigger mandatory GDPR breach notifications, regulatory investigations, and potential enforcement actions. The reputational damage from exposing 2.3 million customer records would likely exceed direct financial costs (IBM Security, 2023).

Likelihood (Medium): Customer data APIs present multiple attack surfaces—external APIs face credential stuffing and brute-force attempts, while internal APIs, accessed by dozens of employees and partners, are at risk of phishing compromises. However, basic security controls (HTTPS, rate limiting) prevent trivial attacks.

Impact (High): GDPR penalties could reach tens of millions of euros. Even a 15% customer defection rate would cost $45 million in annual booking revenue. The breach would undermine the AI-driven personalization strategy and trigger ongoing class-action lawsuits.

Recommended Controls

OAuth 2.0 with Multi-Factor Authentication: Replace basic API keys with OAuth 2.0 authentication using JSON Web Tokens (JWT) that expire after a limited time. Implement mandatory multi-factor authentication for all API access, requiring both a password/token and a second factor (authenticator app, SMS, or hardware token). MFA dramatically reduces the effectiveness of stolen credentials by requiring attackers to compromise multiple independent factors. This control should apply to all customer-facing, employee-facing, and partner-facing APIs without exception.

Role-Based Access Control and Least Privilege: Implement granular RBAC to ensure employees and partners access only the customer data necessary for their roles. Customer service representatives should see only data for customers they are actively assisting. Marketing analysts should access anonymized aggregate data rather than individual PII. Third-party integration partners should have read-only access to minimal data sets required for their integrations. Regular quarterly access reviews should identify and revoke unnecessary permissions. Just-in-time access provisioning, which grants elevated permissions temporarily for specific tasks and automatically revokes them afterward, further limits exposure windows (NIST, 2023).

Data Loss Prevention and Monitoring: Deploy DLP systems that monitor and block attempts to exfiltrate customer data via email, cloud storage, USB drives, or other channels. DLP policies should flag bulk downloads of customer records, unusual access patterns, and transfers to external

destinations. Integrate DLP alerts with Security Information and Event Management (SIEM) systems to correlate data access anomalies with other security events. Establishing behavioral baselines helps identify insider threats. For example, a customer service representative suddenly accessing 10 times as many customer records as usual would trigger an investigation.

Comprehensive Audit Logging: Implement detailed audit logs that capture every access to customer PII, including what data was accessed, when, from where, and the actions performed. Logs should be tamper-proof, stored in a separate, secure system, and retained for at least 1 year to support forensic investigations and compliance audits. Automated log analysis should identify suspicious patterns such as after-hours access, geographic anomalies (access from unexpected locations), and privilege escalation attempts. GDPR specifically requires organizations to demonstrate accountability in data processing, making comprehensive audit trails a compliance necessity (European Parliament & Council, 2016).

Automated Access Reviews and Deprovisioning: Establish automated workflows that immediately revoke access when employees leave the company or change roles. Conduct formal access reviews every 6 months, during which managers must explicitly approve continued access for team members. Access not explicitly approved should be automatically disabled. This prevents the accumulation of orphaned accounts and excessive privileges over time. Integration with HR systems ensures that termination-triggered deprovisioning occurs within hours, preventing disgruntled former employees from stealing data as they exit.

3.3 AI-Powered Recommendation Engine

Asset Description & Value: WTG's AI-powered recommendation engine is the company's core competitive differentiator in the crowded travel technology marketplace. This proprietary machine-learning system analyzes customer behavior, historical booking patterns, search queries, and stated preferences to deliver personalized travel recommendations. Running entirely on AWS cloud infrastructure, the engine processes millions of data points daily, continuously refining its models to predict customer preferences with increasing accuracy. The system generates approximately $12 million in incremental annual revenue through improved conversion rates, higher average booking values, and reduced customer acquisition costs. The recommendation algorithms constitute significant intellectual property, reflecting years of investment in data science and providing a competitive advantage**.**

Major Vulnerability: Cloud infrastructure misconfigurations exposing ML model APIs, training data, and algorithmic IP. Common issues include overly permissive S3 bucket policies, security groups with 0.0.0.0/0 source IPs, unencrypted data volumes, and missing multi-factor authentication. A single misconfigured resource can expose the entire ML pipeline.

Likelihood (Medium): Cloud misconfigurations are extremely common. Research shows that most cloud incidents stem from customer misconfigurations. WTG's ML infrastructure comprises dozens of interconnected resources (S3 buckets, EC2 instances, Lambda functions), creating opportunities for mistakes. However, basic security practices (encryption, VPCs, IAM) prevent egregious exposures.

Impact (Medium): While serious, the compromise primarily threatens competitive advantage rather than regulatory compliance. Competitors gaining access to WTG's ML models could replicate personalization capabilities, eroding the $12 million revenue advantage. Exposure of training data would reveal business intelligence but would primarily contain behavioral analytics rather than sensitive PII, limiting regulatory exposure.

Recommended Controls

Cloud Security Posture Management (CSPM): Deploy automated CSPM tools that continuously scan cloud infrastructure for misconfigurations against security benchmarks such as CIS AWS Foundations. CSPM provides real-time alerts when resources are misconfigured, for example, when an S3 bucket containing training data is accidentally made publicly readable or when a security group opens SSH to the entire internet. These tools automatically enforce security baselines, preventing configuration drift from introducing vulnerabilities. Integration with infrastructure-as-code pipelines ensures that security checks occur before deployment, rather than discovering problems in production (NIST, 2024).

Encryption at Rest and in Transit: Encrypt all ML training data, model parameters, and customer behavior datasets using AWS KMS-managed encryption keys. Enable encryption for EBS volumes, S3 buckets, and database snapshots that contain ML-related data. Enforce TLS 1.3 for all API communications between ML components. Encryption ensures that even if storage resources are misconfigured and allow unauthorized access, the data remains protected. Use customer-managed keys rather than AWS default keys to maintain control over the encryption key lifecycle and access policies.

Network Segmentation and Isolation: Deploy ML infrastructure in dedicated, isolated VPCs, separate from customer-facing web applications and internal corporate networks. Use private subnets for training jobs and model storage, and use API Gateway to provide controlled access to inference endpoints. Implement security groups following least-privilege principles. For example, training clusters should accept connections only from data ingestion processes, not from the internet. This segmentation limits lateral movement if a single component is compromised, preventing the spread to the entire ML pipeline.

API Authentication and Rate Limiting: Protect ML inference APIs with robust authentication (OAuth tokens and rotating API keys) and aggressive rate limiting to prevent abuse. Unauthorized access to recommendation APIs could enable competitors to reverse-engineer models through systematic queries. Rate limiting prevents bulk scraping while supporting legitimate application traffic. Implement API request logging and anomaly detection to identify suspicious usage patterns that indicate reconnaissance or competitive intelligence-gathering attempts.

3.4 Mobile Application Platform

Asset Description & Value: WTG's mobile application platform comprises iOS and Android applications that serve as the primary customer interface, with 1.8 million monthly active users representing 68% of total bookings. The mobile apps provide full travel search, booking, payment,

and itinerary management capabilities, integrating with backend systems via RESTful APIs. Mobile has become mission-critical for WTG's business as customers increasingly prefer mobile booking for convenience, and the apps enable personalized push notifications that drive additional bookings and upselling. The apps store session data, cached search results, booking history, and payment tokens locally on user devices to deliver responsive, offline-capable experiences.

Major Vulnerability: Insecure data storage on mobile devices. Apps currently cache authentication tokens, booking details, the last 4 digits of payment cards, and customer PII using weak encryption or in plaintext. iOS apps store sensitive data in UserDefaults and unencrypted SQLite databases rather than in the iOS Keychain. Android apps fail to use Android Keystore and instead use shared preferences with inadequate protection. Lost, stolen, or malware-compromised devices could enable data extraction, compounded by WTG's inability to remotely wipe customer-owned devices.

Likelihood (Medium): Approximately 70 million smartphones are lost or stolen annually in the US. Mobile malware increasingly targets banking and travel apps. However, exploitation requires either physical device access or malware infection, both of which require a targeting opportunity. Average attackers typically wipe devices for resale rather than extract app data.

Impact (Medium): Mobile data exposure affects individual customers rather than creating a systemic breach. A compromised device exposes one customer's data, which is serious for that individual but limited in scope. However, at a 1.8 million-user scale, even small compromise percentages create a significant customer service burden, reputational concerns, and potential regulatory reporting obligations.

Recommended Controls

Secure Keychain and Keystore Implementation: Immediately migrate all sensitive data to platform-provided secure storage, iOS Keychain for iOS apps, and Android Keystore for Android apps. These platform features provide hardware-backed encryption, secure key management, and protection against jailbreak or root access attempts. Authentication tokens, payment data, and customer PII should never be stored in UserDefaults, SharedPreferences, or unencrypted databases. This is not merely best practice but increasingly a compliance requirement under privacy regulations and payment card industry standards that mandate protection of sensitive data at rest (Payment Card Industry Security Standards Council, 2022).

Mobile Application Security Testing (MAST): Integrate automated mobile app security testing into the CI/CD pipeline to identify insecure storage, hardcoded secrets, and other mobile-specific vulnerabilities before production release. Static analysis (examining code for vulnerabilities) and dynamic analysis (testing running apps) should be mandatory gates in the development process. Regular penetration testing by mobile security specialists should validate that sensitive data is properly protected and that the apps resist common attack techniques, including binary reverse engineering, runtime manipulation, and local data extraction.

Certificate Pinning and TLS Validation: Implement certificate pinning to prevent man-in-the-middle attacks in which attackers intercept API communications via proxy tools. Certificate pinning ensures the app trusts only WTG's specific TLS certificates, not any certificate signed by a trusted CA. This prevents attackers on compromised WiFi networks from intercepting authentication tokens or payment data in transit. Proper TLS validation, combined with pinning, provides defense-in-depth for API security, protecting data both at rest on the device and in transit to backend systems.

Remote Wipe and Session Management: Implement remote wipe capabilities that allow security teams to erase sensitive app data when customers report device loss or theft. Use short-lived authentication tokens (valid for minutes or hours, not days) that automatically invalidate on logout or suspicious activity. Session management should require re-authentication for sensitive operations, such as payment changes, even within active sessions. By minimizing token validity and enabling remote data deletion, WTG can significantly limit exposure from lost devices.

Mobile Threat Defense and Device Security Checks: Deploy mobile threat defense (MTD) SDKs to detect jailbroken or rooted devices, identify malware infections, and warn users of risky network connections. The app should refuse to process payment operations on compromised devices that lack basic security protections. While this may create minor friction for some users, it protects both customers and WTG from operating in inherently insecure environments. Additionally, implement security awareness prompts that encourage users to enable device encryption, use strong device PINs, and keep operating systems up to date. Educating customers improves their security posture as part of the broader defense strategy.

Risk Summary and Prioritization

4.1 Asset Risk Summary

Table 4 provides an executive summary of all four assessed assets with their corresponding data classifications, vulnerabilities, likelihood ratings, impact ratings, and overall risk scores.

Table 4. Summary of Assets, Classifications, Vulnerabilities, Likelihood, and Impact Ratings

Asset	Classification	Vulnerability	Likelihood	Impact	Risk Score
Customer Payment Processing	Restricted	SQL Injection	Medium (2)	High (3)	**6 - HIGH**
Customer Personal Data	Confidential	Weak Authentication	Medium (2)	High (3)	**6 - HIGH**
AI Recommendation Engine	Confidential	Cloud Misconfiguration	Medium (2)	Medium (2)	**4 - MODERATE**
Mobile Application	Internal	Insecure Data Storage	Medium (2)	Medium (2)	**4 - MODERATE**

4.2 Recommended Security Controls Summary

Table 2 summarizes the recommended security controls for each identified vulnerability, organized by asset for executive review and prioritization. (NIST, 2023).

Table 5. Recommended Security Controls for Major Vulnerabilities

Asset	Risk Score	Recommended Controls (Mitigations)
Customer Payment Processing	**6 - HIGH**	Input validation & parameterized queries; Web Application Firewall (WAF); Database patching & hardening; Strict access control; Encryption and tokenization, Quarterly penetration testing
Customer Personal Data Repository	**6 - HIGH**	OAuth 2.0 with MFA; Role-based access control; Data Loss Prevention (DLP); Comprehensive audit logging; Automated access reviews, Access reviews & deprovisioning
AI Recommendation Engine	**4 - MOD**	Cloud Security Posture Management (CSPM); Encryption at rest and in transit; Network segmentation; API authentication and rate limiting.
Mobile Application	**4 - MOD**	Secure keychain/keystore; Mobile Application Security Testing (MAST); Certificate pinning; Remote wipe capability; Mobile threat defense.

4.3 Risk Assessment Matrix

Figure 1 visualizes WTG's four critical assets on a likelihood-impact risk matrix, enabling executive prioritization of mitigation investments based on both the probability of occurrence and the potential business consequences.

Figure 1. WTG Risk Assessment Matrix - Asset Prioritization by Likelihood and Impact

			Likelihood of Occurrence →		
Impact ↓	**Frequent**	**Probable**	**Conceivable**	**Improbable**	**Remote**
Critical	**Critical**	**Critical**	**High**	**Medium**	**Low**
High	**Critical**	**High [Assets 1,2]**	**Medium**	**Medium**	**Low**
Moderate	**High**	**Medium [Assets 3,4]**	**Medium**	**Low**	**V.Low**
Low	**Medium**	**Low**	**Low**	**Low**	**V.Low**
Info	**Low**	**Low**	**V.Low**	**V.Low**	**V.Low**

Matrix Interpretation: Assets 1 & 2 (Customer Payment Processing and Personal Data Repository) are positioned in the HIGH risk zone (orange), requiring immediate prioritized mitigation. Assets 3 & 4 (AI Recommendation Engine and Mobile Application Platform) are positioned in the MEDIUM risk zone (yellow) and require standard security controls.

Asset Positioning:

- Assets 1 & 2: Customer Payment Processing + Personal Data → HIGH RISK (Orange zone)
- Assets 3 & 4: AI Engine + Mobile App → MODERATE RISK (Yellow zone)

This risk matrix enables executive decision-making by visualizing which assets require immediate mitigation investment (orange zone) versus standard security controls (yellow zone). Assets located in HIGH-risk zones require prioritized budget allocation and board-level attention to protect WTG's revenue streams, regulatory compliance, and customer trust.

Conclusion

Despite widespread adoption of formal risk assessment methodologies, cybersecurity breaches continue to proliferate (Verizon, 2024) because of the persistent gap between risk identification and effective remediation. Organizations often produce static documentation that fails to drive meaningful security improvements, constrained by budgets, organizational resistance to security controls that impact productivity, insufficient technical expertise, and competing business priorities that relegate security investments to a lower priority than revenue-generating initiatives. Additionally, the cyber threat landscape evolves continuously at a pace that exceeds most organizations' ability to adapt. Threat actors rapidly develop new attack techniques and discover zero-day vulnerabilities faster than security teams can respond. The persistent human factor remains the most challenging vulnerability, and despite extensive training, social engineering attacks continue to succeed (IBM Security, 2023). Furthermore, compliance theater creates a false sense of security when organizations implement controls to satisfy auditors without truly integrating security into operational culture. Ultimately, breaches persist because risk management is an evolving process involving technology, people, and culture. Perfect security is impossible; attackers need only one weakness, while defenders must protect against every vulnerability. Organizations that treat cybersecurity as continuous improvement rather than a compliance checkbox fare better when incidents occur.

Using the results of this assessment, I plan to communicate WTG's risk posture and tolerance in plain business terms to support informed decision-making. I will compile a comprehensive risk register that summarizes each asset, its risk level, and planned mitigations, turning abstract threats into tangible, trackable items. For example, the customer payment processing environment currently has a high risk score of 6 (Medium likelihood × High impact), and implementing the five recommended controls would reduce the residual risk score to 2. A visual risk heat map will illustrate our current position, making the security landscape immediately comprehensible to non-technical executives (NIST, 2018).

I will draft a formal risk appetite statement that sets clear boundaries: 'WTG maintains zero tolerance for risks that could result in unauthorized disclosure of payment card data or customer PII, given regulatory obligations under PCI DSS (Payment Card Industry Security Standards Council, 2022) and GDPR (European Parliament & Council, 2016). WTG accepts a low tolerance for service disruptions exceeding four hours that affect booking capabilities. WTG accepts a moderate tolerance for operational risks that do not directly compromise customer data or revenue.' Quantitative metrics, such as the percentage of high-risk findings remediated within 30 days, mean time to patch critical vulnerabilities, and phishing simulation click rates, will provide concrete evidence of the security program's effectiveness. Regular quarterly updates to the risk register and continuous monitoring will keep leadership engaged, ensuring that every risk decision is intentional, documented, and aligned with WTG's business strategy (Whitman & Mattord, 2018).

References

European Parliament and Council of the European Union. (2016). *General Data Protection Regulation (Regulation (EU) 2016/679)*.
https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32016R0679

IBM Security. (2023). *Cost of a data breach report 2023*. IBM Corporation.
https://www.ibm.com/reports/data-breach

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments (NIST Special Publication 800-30 Rev. 1)*. U.S. Department of Commerce.
https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf

National Institute of Standards and Technology. (2018). *Managing information security risk: Organization, mission, and information system view (NIST Special Publication 800-39)*. U.S. Department of Commerce.
https://csrc.nist.gov/pubs/sp/800/39/final

National Institute of Standards and Technology. (2023). *Security and privacy controls for information systems and organizations (NIST Special Publication 800-53 Rev. 5)*. U.S. Department of Commerce.
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf

National Institute of Standards and Technology. (2024). *Cybersecurity framework (CSF) 2.0*. U.S. Department of Commerce.
https://www.nist.gov/cyberframework

OWASP Foundation. (2021). *OWASP application security verification standard 4.0.3*.
https://owasp.org/www-project-application-security-verification-standard/

Payment Card Industry Security Standards Council. (2022). *Payment card industry data security standard: Requirements and security assessment procedures (Version 4.0)*.
https://www.pcisecuritystandards.org/document-library

Verizon. (2024). *2024 data breach investigations report*. Verizon Enterprise.
https://www.verizon.com/business/resources/reports/dbir/

Whitman, M. E., & Mattord, H. J. (2018). *Management of information security* (6th ed.). Cengage Learning.